GUÍA PRÁCTICA DE LABORATORIO N.º 10

Autenticación JWT entre PharmaMobile y PharmaSoft

Proyecto	PharmaMobile sobre PharmaSoft
Estudiante	Luciana Gutierrez
Tecnologías	Kotlin Multiplatform · Ktor Client · Koin · Compose
Verificación	13 de octubre de 2026
Rama local	feature/auth-jwt-Gutierrez

Resultado general

Se implementó la autenticación JWT completa en la capa compartida, con almacenamiento seguro por plataforma, Bearer automático, recuperación de sesión, permisos, manejo de 401/403 y UI Compose. Oracle y PharmaSoft se levantaron y probaron realmente. Android genera APK y las 39 pruebas pasan; el código iOS compila, pero no se ejecutó por falta de Mac/Xcode.

1. Recursos analizados y alcance

Se revisaron la guía oficial, la colección de pruebas de seguridad, los scripts SQL entregados, el backend oficial actualizado y la estructura actual del proyecto Kotlin Multiplatform. La colección Postman se usó como especificación de escenarios; no se añadió como dependencia de PharmaMobile.

Recurso	Uso en la implementación
Guía Práctica N.º 10	Criterios de JWT, sesión, seguridad, permisos y evidencias.
Colección Postman	Contratos de login, /auth/me, 401, 403, roles y rutas protegidas.
RAR SQL	Comparación de migraciones V2/V3 para usuarios, roles y permisos.
PharmaSoft oficial	Fuente real del contrato y backend ejecutado en puerto 8080.
PharmaMobile	Implementación KMP en commonMain, Android e iOS.

Decisiones de seguridad

• No se incluyó ningún JWT, secreto de firma ni contraseña en el repositorio o en este informe.

• La cabecera Authorization se censura en debug y el registro HTTP se desactiva en release.

• No se inventó una nueva configuración Docker: se reutilizó el contenedor Oracle local existente.

• No se fabricaron evidencias iOS ni capturas del emulador bloqueado.

La rama de trabajo es feature/auth-jwt-Gutierrez. No se realizó push. Los cambios pendientes de la Sesión 08 se conservaron y se mantuvieron fuera del alcance.

2. Oracle y backend PharmaSoft

Se actualizó la copia local de PharmaSoft mediante avance rápido hasta el commit oficial **fff44f9 (seguridad)**. El backend compiló y arrancó con Spring Boot. La base Oracle respondió con el esquema PHARMADB y Flyway aplicó las migraciones de seguridad, dejando el esquema en versión 3.

Elemento	Valor comprobado
Contenedor	pharmasoft-oracle
Imagen	gvenzl/oracle-free:23.26.1-slim-faststart
Puerto	127.0.0.1:1522 → 1521
Servicio	FREEPDB1
Esquema	PHARMADB
Persistencia	Volumen pharmasoft-oracle-data
Backend	Spring Boot en http://localhost:8080

Corrección del SQL entregado

El V2 incluido en el RAR contiene una línea suelta “BD SEGURIDAD”, que no es una sentencia SQL válida. No se copió de forma ciega. La migración oficial de PharmaSoft conserva el modelo requerido y corrige esa línea como comentario; esa fue la versión ejecutada por Flyway.

Pruebas HTTP reales

Escenario	Resultado
GET /api/health sin token	200
GET /api/v1/productos sin token	401
POST /api/v1/auth/login como admin	200 · Bearer · JWT válido · ADMIN
GET /api/v1/auth/me como admin	200
GET /api/v1/productos como admin	200
Login como almacen	200 · ALMACENERO
Clientes como almacen	403

3. Arquitectura implementada

Capa	Componentes	Responsabilidad
Red	HttpClientFactory	JSON, timeout, Auth Bearer y logging seguro.
DTO	LoginDto	Contrato exacto de login y usuario actual.
Mapper	SesionMapper	Convierte DTO a dominio sin filtrar Ktor a UI.
Dominio	Sesion, Credenciales, AuthRepository	Estado y contrato independiente de plataforma.
Datos	AuthRepositorioRest	Login, /auth/me, persistencia y logout.
Seguridad	AlmacenSeguro	Keystore Android y Keychain iOS.
DI	Koin	Cliente, almacenamiento, repositorio y ViewModels.
Presentación	SesionViewModel + Compose	Estados, login, permisos y cierre de sesión.

Flujo de autenticación

1. Compose entrega credenciales validadas al SesionViewModel.
2. AuthRepositorioRest ejecuta POST auth/login sin Bearer previo.
3. El token se guarda en el almacén seguro y se limpia la caché del proveedor.
4. Ktor agrega Bearer automáticamente a las rutas protegidas.
5. Al reiniciar, /auth/me valida el token y reconstruye la sesión.
6. Logout elimina el token y devuelve al login.

Comportamiento por estado HTTP

Estado	Comportamiento móvil
200	La respuesta se mapea a dominio y actualiza la UI.
401	Se elimina el token, se limpia la sesión y se muestra sesión expirada.
403	Se conserva la sesión y se informa falta de permisos.
Timeout/red	Mensaje controlado; no se expone la excepción técnica.

4. Seguridad por plataforma y permisos

Android

• Android Keystore genera una clave AES de 256 bits.

• AES/GCM cifra el JWT antes de persistirlo.

• SharedPreferences conserva únicamente texto cifrado e IV; nunca el token en claro.

• La clave criptográfica no es exportable desde AndroidKeyStore.

iOS

• Keychain Services guarda el JWT como contraseña genérica.

• SecItemCopyMatching recupera el token y SecItemDelete lo elimina.

• El código compila para iosSimulatorArm64 en Windows; la ejecución real requiere macOS/Xcode.

Autorización visible en Compose

Permiso	Efecto en la interfaz
CATALOGO_LEER	Muestra Productos y permite consultar el catálogo.
CATALOGO_ESCRIBIR	Muestra crear, editar y eliminar productos.
CLIENTES_LEER	Muestra Clientes y su acceso rápido.
VENTAS_LEER	Muestra Pedidos y su acceso rápido.

Ocultar controles mejora la experiencia, pero la seguridad efectiva permanece en PharmaSoft. Aunque un cliente manipulado intente llamar una ruta prohibida, el backend responde 403.

5. Verificación técnica

Comando final ejecutado

```
.\gradlew.bat :shared:testAndroidHostTest :shared:compileKotlinIosSimulatorArm64
:androidApp:assembleDebug
```

Validación	Resultado
APK Android	GENERADO
Compilación Kotlin iOS Simulator ARM64	CORRECTA
Pruebas Android host	39 ejecutadas
Fallos / errores / omitidas	0 / 0 / 0
Resultado Gradle	BUILD SUCCESSFUL

Pruebas nuevas de autenticación

• El login no envía Authorization.

• La respuesta de login se mapea y el token se guarda.

• Ktor adjunta Bearer automáticamente en una petición protegida.

• La recuperación de sesión consulta /auth/me.

• HTTP 401 se traduce a SesionExpirada.

• HTTP 403 se traduce a SinPermiso.

Limitación de ejecución Android

El AVD Medium_Phone quedó bloqueado con “System UI isn't responding”. Se intentó un arranque limpio y un segundo AVD, pero la automatización de ADB no permaneció disponible. Por integridad académica, el informe no presenta capturas falsas ni declara como ejecutados login, persistencia y logout visuales. El APK y las pruebas automatizadas sí quedaron verificados.

6. Matriz final de evaluación

N.º	Criterio	Estado	Evidencia
1	Ktor Auth	CUMPLE	Dependencia y plugin Bearer.
2	DTO	CUMPLE	LoginRequest/Response y UsuarioActual.
3	Mapper	CUMPLE	Conversión a Sesion.
4	Repositorio	CUMPLE	Login, recuperación y logout.
5	Bearer automático	CUMPLE	Login excluido y prueba MockEngine.
6	Almacenamiento seguro	CUMPLE EN CÓDIGO	Keystore y Keychain.
7	Koin + ViewModel	CUMPLE	DI y estados de sesión.
8	Compose	CUMPLE EN CÓDIGO	Login, carga, error, rol y logout.
9	401/403 y permisos	CUMPLE	Limpieza, mensajes y UI filtrada.
10	Prueba multiplataforma	PARCIAL	Android compila; iOS sin ejecución.

Conclusión

La solución cubre la arquitectura y seguridad pedidas por la Guía 10 y se integra con el PharmaSoft oficial sobre Oracle. El código queda compilable y probado automáticamente. Para cerrar el criterio de evidencia visual faltan únicamente las capturas manuales del flujo Android; la ejecución iOS queda legítimamente pendiente hasta disponer de una Mac.

Estado de entrega

• Rama local: feature/auth-jwt-Gutierrez.

• Sin push, conforme a la solicitud.

• Sin reescribir historial ni alterar archivos pendientes de otras sesiones.

• Informe y detalle técnico guardados en el repositorio local.

7. Guía exacta para completar las capturas

1. Abrir Docker Desktop y confirmar que pharmasoft-oracle aparece en estado Up con el puerto 1522.

2. En pharmaSoft ejecutar mvn.cmd spring-boot:run y capturar las líneas de Flyway versión 3 y Started.

3. Abrir http://localhost:8080/swagger-ui/index.html; ejecutar /api/health y capturar 200.

4. Ejecutar POST /api/v1/auth/login con un usuario de prueba; capturar 200 ocultando completamente el token.

5. Ejecutar GET /api/v1/productos sin autorizar y capturar 401.

6. Iniciar Medium_Phone con Cold Boot Now, instalar androidApp-debug.apk y abrir PharmaMobile.

7. Capturar la pantalla de login sin escribir contraseña visible.

8. Iniciar como admin y capturar el menú completo con el rol ADMIN.

9. Cerrar y volver a abrir la app; capturar que la sesión válida se recupera.

10. Cerrar sesión; capturar el regreso al login y el aviso de cierre correcto.

11. Iniciar como almacen y capturar Productos disponible y Clientes ausente.

12. En Logcat filtrar HttpClient; capturar Authorization censurado, nunca el JWT.

13. Abrir shared/build/reports/tests/testAndroidHostTest/index.html y capturar 39 tests, 0 fallos.

14. No presentar evidencia iOS hasta ejecutarla realmente en macOS con Xcode.

Las capturas deben guardarse en docs/evidencias_sesion10 con nombres numerados. Ninguna imagen debe exponer contraseñas, JWT, cookies o el secreto del backend.